



北京邮电大学

Beijing University of Posts and Telecommunications

第二章 网络空间和网络空间安全

(网络空间安全治理课程)



主讲人：王小娟



E-mail: wj2718@163.com



目录

CONTENTS

01

网络空间的定义

02

网络空间的分层

03

网络安全空间的定义

04

网络安全空间治理的定义



北京邮电大学

Beijing University of Posts and Telecommunications

Part.01

网络空间的定义

信息安全概念的出现

- “网络空间”的定义来自于我们传统意义上说的“信息安全”，但是又有别于“信息安全”
- 信息安全可以追溯至**二战时期**
- 直到20世纪40年代，**信息安全和通信保密**才进入学术界的视野
- 20 世纪50 年代，相关科技文献中开始出现“信息安全”一词
- 20 世纪90 年代，“信息安全”一词已经陆续出现在各国和地区的政策文献中，相关的学术研究文献也逐步增加



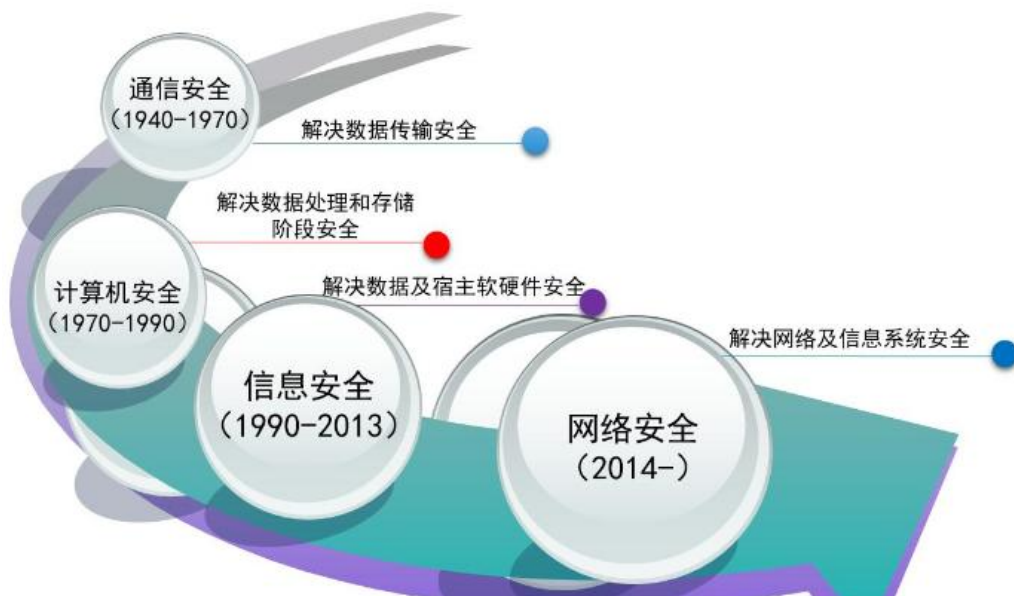
信息安全十大领域

➤ 总部设在美国佛罗里达州的国际信息系统安全认证组织(International Information Systems Security Consortium) 将信息安全划分为**十大领域**，包括：

- | | |
|-----------|---------------|
| ——物理安全 | ——商务连续和灾害重建计划 |
| ——安全结构和模式 | ——应用和系统开发 |
| ——通信和网络安全 | ——访问控制领域 |
| ——密码学领域 | ——安全管理实践 |
| ——操作安全 | ——法律侦察和道德规划 |



网络空间安全概念出现的背景



- 近年来，随着全球**互联网的快速发展**和**社会信息化程度的快速推进**，相比物理的现实社会，网络空间中的数字社会在各个领域所占的比重越来越大。数字化社会的数量增长带来了质量的变化，以**数字化、网络化、智能化、互联化、泛在化**为特征的网络社会，为信息安全带来了新技术、新环境和新形态。
- 信息安全主要体现在现实物理社会的情况发生了变化，开始更多地体现在**网络安全领域**，反映在跨越时空的网络系统和网络空间之中，反映在全球化的互联互通之中。

分析



- 从上面的分析可知，“网络安全”的定义来源于在“网络空间”中的信息安全涵义的外延，因此必须先弄明白“网络空间” (cyberspace)这个概念的内涵与外延。

“网络空间” 来自于 **“网络”** (cyber)。

网络的定义

- 一般认为，网络是由**节点和连接边**构成，用来表示**多个对象及其相互联系的互连系统**。
- 现实中的信息网络，可以抽象地概括为：将各个孤立的**“端节点”**（信息的生产者和消费者），通过**“连接边”**（物理或虚拟链路）将之连接在一起，进而实现各端节点间通过**“交换节点”**进行转发，以实现载荷在端节点之间进行交换。
- 其中**“载荷”**是网络中数据与信息的表达形式，如电磁信号、光信号、量子信号、网络数据等。
- 网络的四个基本要素：**端节点、交换节点、连接边、载荷**。
- 该定义反映出“网络”的含义很广泛，不仅互联网符合这一特征，**电信网、物联网、传感网、工控网、广电网**等各类电磁系统所构成的信息网络都符合“网络”的描述，因而对网络的讨论就**不再是仅限于互联网**这么狭窄。

网络空间的直观定义



- **网络空间**是一种人造的电磁空间，其以终端、计算机、网络设备等为载体，人类通过在其上对数据进行计算、通信来实现特定的活动。
- 在这个空间中，**人、机、物可以被有机地连接在一起进行互动**，可以产生影响人们生活的各类信息，包括内容、商务、控制信息等

网络空间的学术定义 (1)

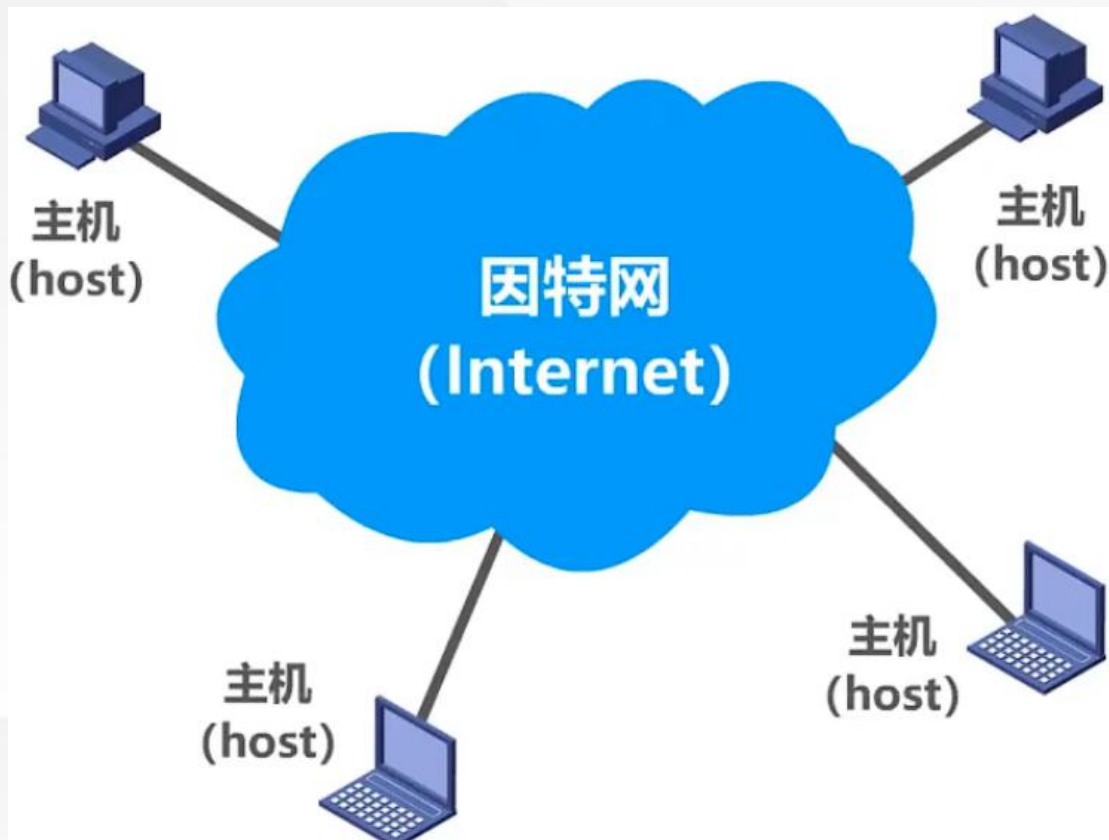


- 网络空间是人类通过**网络角色**，依托**信息通信技术系统**来进行**广义信号**交互的人造**活动空间**

网络空间的学术定义 (2)

- **网络角色**是指产生、传输广义信号的主体，反映的是人类的意志；
- **信息通信技术系统**包括互联网、电信网、无线网、移动网、广电网、物联网、传感网、工控网、卫星网、数字物理系统（CPS）、在线社交网络、计算系统、通信系统、控制系统等光电磁或数字信息处理设施；
- **广义信号**是指基于光、电、声、磁等各类能够用于表达、存储、加工、传输的电磁信号，以及能够与电磁信号进行交互的量子信号、生物信号等信号形态；这些信号通过在信息通信技术系统中进行存储、处理、传输、展示而成为信息；
- **活动**是指用户以信息通信技术为手段、对广义信号进行操作以表达人类意志的行为；操作包括产生信号、保存数据、修改状态、传输信息、展示内容等，可称为“信息通信技术活动”。

网络空间四要素



- 网络空间的四要素：
- 虚拟角色、平台、数据、活动
- 虚拟角色强调主体（即用户）
- 平台强调载体（即基础设施）
- 数据强调客体（即载荷）
- 活动强调行为



北京邮电大学

Beijing University of Posts and Telecommunications

Part.02

网络空间的分层

网络空间安全的4层次模型

应用层的安全

数据层的安全

系统层的安全

设备层的安全

- **设备层的安全**应对在网络空间中信息系统设备所面对的安全问题；
- **系统层的安全**应对在网络空间中信息系统自身所面对的安全问题；
- **数据层的安全**应对在网络空间中处理数据的同时所带来的安全问题；
- **应用层的安全**应对在信息应用的过程中所形成的安全问题。



北京邮电大学

Beijing University of Posts and Telecommunications

Part.03

网络空间安全的定义

网络空间安全概念的兴起

- 20 世纪90 年代以来，信息安全开始向网络安全聚焦，经历了一个逐步发展和逐步强化的过程。
- 在20 世纪90 年代广泛使用的“信息安全”一词。
- 在进入21世纪的十多年中，已逐步与“网络安全”和“网络空间安全”并用，而网络安全与网络空间安全的使用频度不断增加，这在发达国家的相关文献中尤为突出。
- 尽管信息安全至今仍然是人们常用的概念，但随着2002年世界经合组织通过了关于信息系统和网络安全的指南文件，特别是2003 年美国发布了网络空间战略的国家文件，“网络安全”和“网络空间安全”开始成为较之“信息安全”更为社会和业界所聚焦和关注的概念，在理论研究和实践中也使用得更加频繁。

网络空间安全的定义



- 从信息论角度来看，系统是载体，信息是内涵。因此从定义上而言，网络空间是所有信息系统的集合，是人类生存的信息环境，人在其中与信息相互作用相互影响。
- 网络空间安全则是指“在网络空间中广泛存在的信息系统，可能对网络空间(Cyber)、物理空间(Physical)和社会空间(Society)造成的安全问题”，例如常见的终端安全、网络内容安全、网络舆情监测等。

网络空间安全的理解

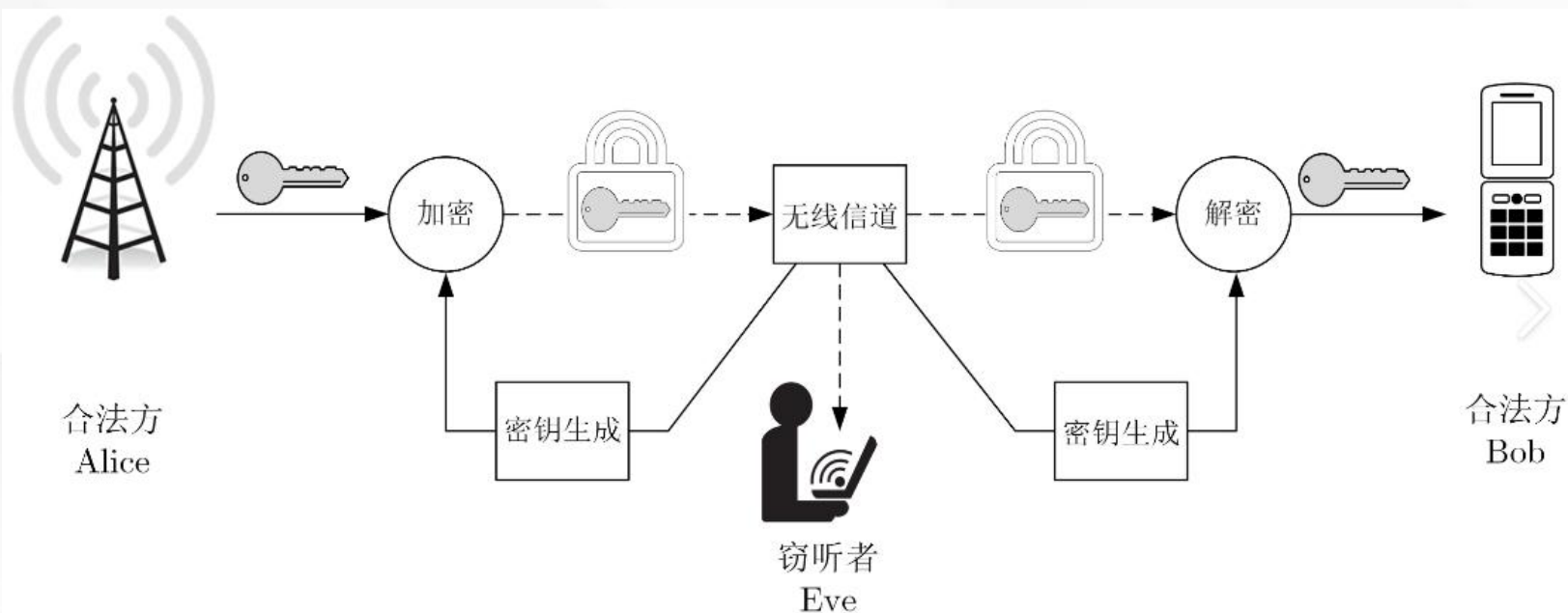


网络安全

- 从网络空间安全的内涵与外延而言，网络空间安全可以指称信息安全或网络安全，但侧重点是与陆、海、空、太空等并行的空间概念，并一开始就具有军事性质；
- 与信息安全相比较，网络安全与网络空间安全反映的信息安全更立体、更宽域、更多层次，也更多样，更能体现出网络 and 空间的特征，并与其他安全领域更多地渗透与融合。

网络空间安全的四项主要内容

- 1.物理层安全
- 主要研究针对**各类硬件的恶意攻击和防御技术**，以及硬件设备在网络空间中的安全接入技术。在恶意攻击和防御方面的主要研究热点有**侧信道攻击、硬件木马检测方法和硬件信任基准**等，在设备接入安全方面主要研究基于设备指纹的身份认证、信道及设备指纹的测量与特征提取等。此外，物理层安全还包括**容灾技术、可信硬件、电子防护技术、干扰屏蔽技术**等。



侧信道攻击

不直接破解算法，而是利用系统实现的物理或行为特征推断机密信息

➤ 什么是侧信道：

- 正信道：系统正常的数据输入、输出（如密码验证结果）。
- 侧信道：系统运行中无意泄露的物理信号（如CPU执行加密时的功耗波动，操作耗时差异等）。

➤ 举例：

RSA 加密算法中，不同密钥位的运算会导致 CPU 晶体管开关次数差异，进而产生可检测的功耗波动。攻击者通过分析这些波动，可逐步缩小密钥可能的取值范围，最终破解密钥。

电磁侧信道攻击（EM攻击）通过监测设备运行时的电磁辐射，分析电流变化与数据流之间的关联性，从而破解密码或提取敏感信息。



攻击者将天线直接放置在设备处理器上方的 EM 攻击设置

侧信道攻击的防御

➤ 硬件方面：

物理隔绝：通过物理方法如屏蔽、滤波和隔离来减少设备产生的电磁辐射。

时间随机化：在执行敏感操作时引入时间上的不可预测性，使得攻击者难以通过时间侧信道进行攻击。

功耗平衡：确保设备在执行不同操作时的功耗尽可能保持一致，从而减少能量侧信道信息的泄露。

➤ 软件方面：

算法优化：对现有算法进行优化，减少关键操作的执行时间差异。

代码混淆：通过改变正常的程序执行流程来混淆潜在的侧信道信号。

访问模式随机化：在访问敏感数据时采用随机化技术，使得数据访问模式不具规律性。

硬件木马检测方法

- 硬件木马：芯片设计、制造或封装阶段被植入的“微型恶意电路模块”
- 检测方法：
 - 静态检测（看外观）：通过显微成像、电路重构等技术手段，对比“设计图纸”与“实际芯片”在晶体管布局、导线走向等方面的物理结构差异
 - 动态检测（看输出）：使芯片处于工作状态（如执行加密、计算任务），对比其“工作时的功能表现”与“正常芯片”的基准表现
 - 侧信道检测（听信号）：不观察芯片内部结构、不依赖功能输出，仅“捕获”其工作时产生的“隐性物理信号”（如耗电波动、电磁辐射）

容灾技术

- 核心目标：业务不中断 · 数据不丢失
- 底层逻辑：以“冗余”抵御“失效”，通过多维度冗余设计，避免单一故障导致系统崩溃
 - 空间冗余：异地 / 同城部署生产中心 + 灾备中心，应对区域灾害
 - 设备冗余：服务器 / 存储集群化，单点故障自动补位
 - 数据冗余：同步 / 异步复制，确保数据多节点留存



网络空间安全的四项主要内容

➤ 2.系统层安全

- 包括系统软件安全、应用软件安全、体系结构安全等层面的研究内容，并渗透到云计算、移动互联网、物联网、工控系统、嵌入式系统、智能计算等多个应用领域，具体包括系统安全体系结构设计、系统脆弱性分析、软件的安全性分析，智能终端的用户认证技术、恶意软件识别，云计算环境下虚拟化安全分析和取证等重要研究方向。



系统安全体系结构设计

➤ 核心目标：机密性，完整性，可用性，可控性，不可否认性

原理名称	核心内涵	典型应用
纵深防御	构建多层防护体系，避免单点失效	外网防火墙→内网 WAF→主机杀毒→应用权限控制
最小权限	仅授予主体完成任务必需的最小权限	普通员工无服务器 root 权限、APP 仅申请必要隐私权限
安全分区	按业务敏感度划分区域，隔离风险	生产区 / 办公区 / DMZ 区物理 / 逻辑隔离，跨区需审批
数据驱动	以数据安全需求为核心设计防护策略	核心业务数据加密传输 + 脱敏存储，普通日志仅审计
持续迭代	动态适配威胁变化，定期更新体系	季度漏洞扫描、年度安全架构评审、应急响应演练

➤ 模型

P2DR 模型：策略（Policy）→防护（Protection）→检测（Detection）→响应（Response）

零信任模型：遵循“永不信任，始终验证”，每一次访问均需身份核验（如多因素认证 MFA）

系统脆弱性分析

给系统 “体检” 找漏洞

➤ 通过技术手段识别系统（硬件 / 软件 / 网络）中可能被利用的安全缺陷，提前规避数据泄露、权限篡改、服务中断等风险。

➤ 关键技术：

漏洞扫描技术：基于漏洞数据库，通过自动化工具发送探测包，匹配系统配置 / 端口 / 协议中的已知漏洞特征；支持主动扫描（主动发送请求）与被动扫描（监听网络流量）。

渗透测试技术：模拟黑客攻击视角，采用“信息收集→漏洞利用→权限提升→横向渗透”流程，验证漏洞的实际可利用性；

分为黑盒测试（无系统内部信息）、白盒测试（全量系统信息）。

静态 / 动态分析技术：

静态分析：不运行程序，通过代码审计工具检查语法漏洞、逻辑缺陷（如缓冲区溢出）；

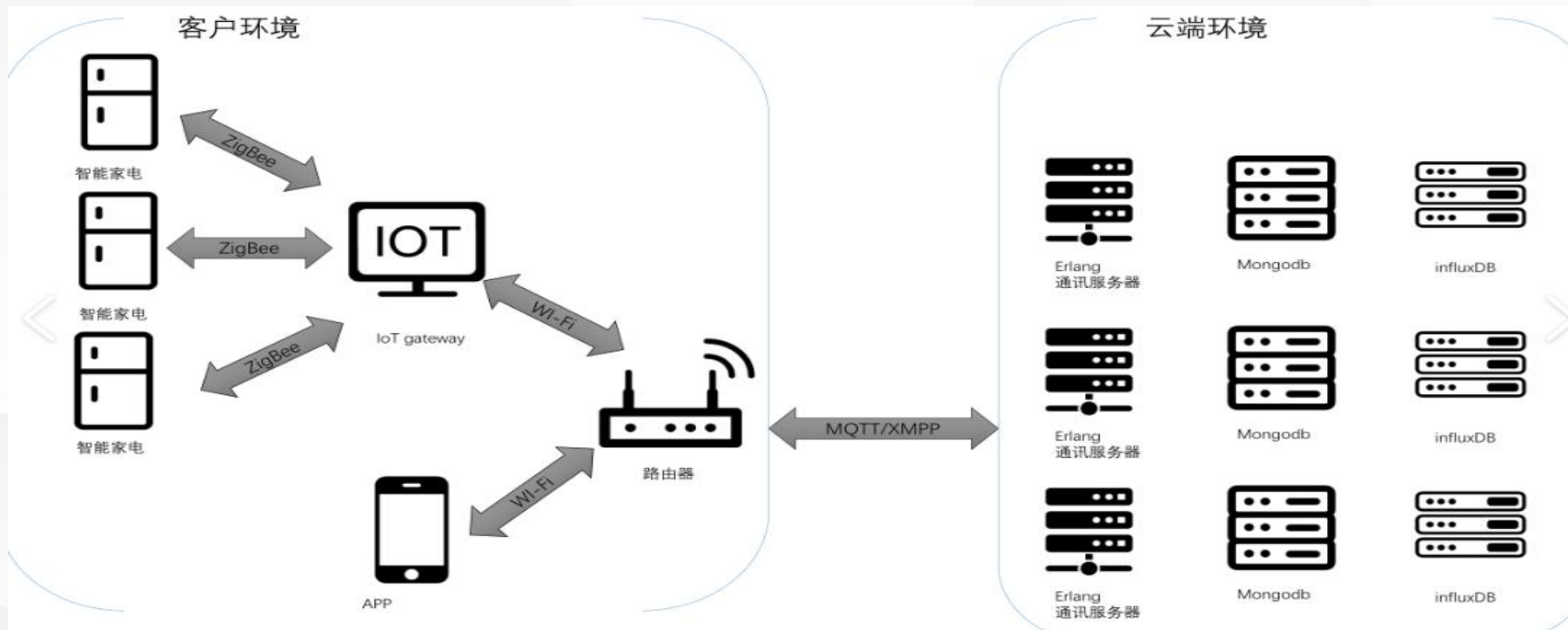
动态分析：运行程序时监控行为，捕捉内存泄露、异常调用等实时脆弱点。

恶意软件识别技术

- 核心目标：区分 “正常程序” 与 “恶意代码” （病毒 / 木马 / 勒索软件等），应对恶意软件迭代
- 基于 “已知特征” 的静态检测：不运行代码，检测已知恶意代码的特征
提取恶意软件 “特征值”，比对文件代码片段
- 基于 “行为” 的动态检测：运行程序观察行为，可识别 “未知恶意软件”
隔离环境（虚拟机 / 容器）中运行，监控恶意行为（加密文件、连未知 IP、改注册表）
- 基于 AI / 机器学习的预测检测：解决 “海量样本 + 变异恶意软件” 识别难题
用海量样本（正常 / 恶意软件）训练模型，自主学习恶意特征（代码规律 / 行为序列），预测新样本 “恶意概率”

网络空间安全的四项主要内容

- 3.网络层安全
- 该层研究工作的主要目标是保证连接网络实体的中间网络自身的安全, 涉及各类无线通信网络、计算机网络、物联网、工控网等网络的安全协议、网络对抗攻防、安全管理、取证与追踪等方面的理论和技术.



网络安全协议

➤ 核心目标：解决 4 大安全风险（机密性，完整性，身份认证，不可否认性）

➤ 底层技术：

技术类型	核心作用	代表算法 / 机制
加密技术	保障机密性	对称加密（AES）、非对称加密（RSA）
哈希算法	保障完整性	SHA-256
数字签名 / 证书	认证身份 + 防抵赖	CA 证书（验证公钥合法性）

➤ 典型协议：

➤ HTTPS（TLS/SSL）：Web 通信（电商、网银）

➤ SSH：远程服务器管理（Linux）

➤ WPA3：Wi-Fi 接入安全

➤ IPSec：企业远程办公（访问内网）

网络对抗攻防技术

- 攻击技术
 - 信息收集: Whois 查询、端口扫描 (Nmap)、社工扒取信息
 - 漏洞利用: SQL 注入、XSS、永恒之蓝漏洞、弱密码突破
 - 权限提升: 内核漏洞提权、Hash 传递攻击
 - 目标达成: 数据窃取、植入勒索病毒、留后门控制
- 防御技术
 - 边界防护: 防火墙、WAF (防 Web 攻击)、IDS/IPS
 - 系统加固: 打补丁、关无用端口、强密码 + MFA
 - 监控检测: 日志审计、流量分析、EDR (终端监控)
 - 应急响应: 隔离主机→清除恶意程序→恢复系统→溯源

网络安全管理技术

技术领域	核心目标	关键工具 / 手段
资产与漏洞管理	摸清家底，消除漏洞风险	资产扫描、CVE 漏洞检测、修复进度跟踪
安全监控与运维	实时感知威胁，快速响应	SIEM（日志聚合分析）、SOC（运营闭环）
数据安全治理	保障数据全生命周期安全	数据分类分级、DLP（防泄漏）、数据加密
合规与风险评估	满足法规，量化风险	合规检查（对标《网安法》）、风险量化计算

3 个核心管理原则

- 全生命周期闭环：资产→风险→防护→处置→优化
- 人机协同闭环：工具自动化支撑 + 人工研判决策
- 持续优化闭环：定期复盘，适配新威胁

网络取证与追踪技术

➤ 核心目标：证据固定，事件还原，攻击者溯源

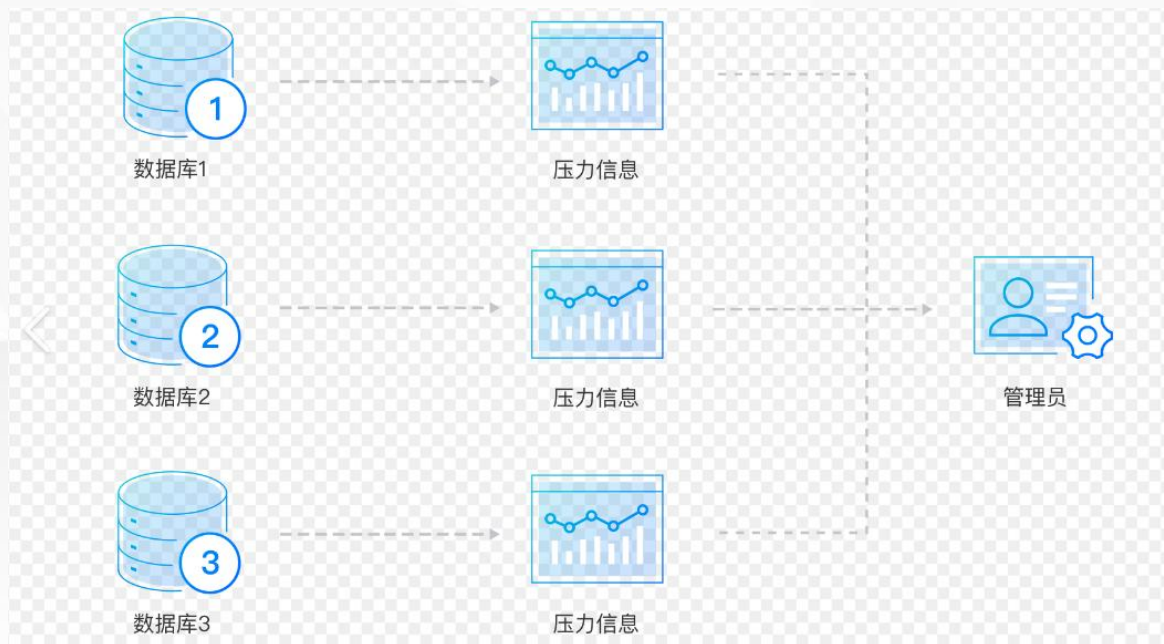
取证类型	核心数据来源	关键手段
终端取证	系统日志、磁盘 / 内存数据	磁盘只读镜像、Volatility 内存抓取
网络取证	流量包、防火墙 / WAF 日志	Wireshark 抓包、流量还原
应用取证	Web / 邮件 / 数据库日志	日志关联分析、邮件头溯源
云环境取证	云操作日志、容器交互记录	跨平台日志聚合、容器镜像提取

➤ 追踪流程：1，初步定位：提攻击 IP / 域名，查 Whois 归属（ISP / 地域）
2，突破隐匿：分析代理 / VPN/Tor 痕迹，匹配终端指纹
3，关联数据：结合 IP 历史行为、恶意程序签名、社工信息
4，落地溯源：调 ISP 日志（法律途径）+ 线下调查确认身份

网络空间安全的四项主要内容

➤ 4.数据层安全

- 数据层安全研究的主要目的是保证数据的机密性、完整性、不可否认性、匿名性等, 其研究热点已渗透到社会计算、多媒体计算、电子取证、云存储等多个应用领域, 具体包括数据隐私保护和匿名发布、数据的内在关联分析、网络环境下媒体内容安全、信息的聚集和传播分析、面向视频监控的内容分析、数据的访问控制等。



数据隐私保护与匿名发布技术

- 核心目标：平衡 “数据利用” 与 “隐私安全”
- 关键技术手段
 - 数据脱敏：
 - 替换（如 “138****5678”）、屏蔽（如身份证号显示前 6 后 4）、加密（敏感字段加密存储，需授权解密）
 - 匿名化：
 - k - 匿名（确保每条数据至少与 k-1 条数据特征一致，无法唯一定位个人）、l - 多样性（避免同一组数据敏感属性单一，如某组全为 “癌症患者”）
 - 差分隐私：
 - 全局差分隐私（对数据集加噪声）、局部差分隐私（用户端加噪声后再上传，如苹果用户数据统计）

数据内在关联分析技术

➤ 核心目标：挖掘 “隐藏关系”

技术类型	核心原理	典型应用场景
统计关联分析	用数学模型量化数据间的相关程度	电商 “购买 A 商品的用户多买 B” 推荐
因果关联分析	区分 “相关” 与 “因果”，定位影响因素	医疗 “某药物与疗效” 的因果验证
图关联分析	将数据抽象为 “节点 - 边”，分析关系网络	金融 “银行卡 - 账户 - 交易” 欺诈识别

➤ 核心挑战

- 数据质量：噪声、缺失值会干扰关联准确性；
- 虚假关联：避免将 “时间相关” 误判为 “因果相关” （如 “冰淇淋销量高→溺水事故多” ）；
- 海量数据：多源、大规模数据需高效算法（如分布式计算）支撑分析效率。

网络环境下媒体内容安全技术

➤ 核心目标：内容合规，版权保护，内容可信

技术类型	核心原理	典型应用场景
内容识别与过滤	用 AI（图像识别、语音识别）检测违规内容，自动拦截 / 标注	社交平台、视频网站过滤不良内容
数字水印技术	在媒体中嵌入隐藏标识（可见 / 不可见），追踪版权归属	影视版权追溯、图片原创保护
内容篡改检测	对媒体内容生成哈希值 / 特征指纹，比对验证完整性	新闻图片防篡改、政务公告真实性校验
访问控制技术	基于权限（如账号、密钥）限制媒体内容查看 / 下载	付费影视、企业内部培训视频管控

数据访问控制技术

➤ 核心目标：最小权限，精准管控，可追溯

技术类型	核心原理	典型应用场景
自主访问控制 (DAC)	数据所有者自主决定 “谁能访问”，可传递权限	个人电脑文件共享（如 Windows 文件夹授权）
强制访问控制 (MAC)	系统按 “主体 / 客体安全级别”（如公开 / 机密）强制匹配，所有者无权限修改	涉密单位、军事系统数据管控
基于角色访问控制 (RBAC)	按 “用户角色”（如财务、HR）分配权限，同一角色权限统一	企业 ERP 系统（财务角色仅访问财务数据）
基于属性访问控制 (ABAC)	结合 “主体属性（职位）、客体属性（数据类型）、环境属性（IP / 时间）” 动态判断权限	远程办公（仅允许公司 IP + 工作时间访问核心数据）



北京邮电大学

Beijing University of Posts and Telecommunications

Part.04

网络空间安全治理的定义

网络空间安全治理的基本概念

治理

- 概念上而言，是“各种管理共同事务方式的总和，是不同利益得以调和的持续行动过程”。
- 研究上而言，认为治理即治国理政，一项发展性极强的管理活动和一种因时而进、因势而新的社会现象。
- 网络安全治理是国家治理思想在网络空间的提升拓展。

中国的网络空间安全治理主张：

- 主权原则应适用于网络空间
- 应该强化联合国在网络空间安全治理中的地位
- 反对网络空间单边主义与双重标准
- 倡导平等共治的命运共同体模式



习近平网络空间安全治理观



- 1. “一体两翼双轮驱动”的网络安全战略观
- 2014 年，习近平在中央网信领导小组首次会议上指出，网络安全和信息化是一体之两翼，驱动之双轮。所谓“一体”，即网络强国的目标主体，这是国家战略，也是目标愿景；所谓“两翼双轮驱动”，即“网络安全”和“信息化”。这犹如鸟之两翼、车之两轮，两者双翼并展、双轮共驱，是网络强国主体目标的实现路径。

习近平网络空间安全治理观



- 2. “网络空间命运共同体”的网络安全共建观
- 站在全球互联网发展治理的高度，2015 年习近平在第二次世界互联网大会上首次提出了“构建网络空间命运共同体”的共建主张，为全球网络安全治理指明了道路和方向，得到了世界各国的纷纷响应。网络空间命运共同体虽然构建于虚拟的网络空间，但依赖于现实世界人们的共同推动和努力。因为无论是网络空间，还是现实世界，其安全治理推动的主体都是人民或网民，这就决定了在虚拟空间与现实世界欲构建的命运共同体之间，必然存在着紧密的逻辑联系。

习近平网络空间安全治理观



- 3. “以人民为中心发展”的网络安全利益观
- 互联网因汇聚不同地域的人们走进同一个世界而成为网络空间，以人民为主体的广大网民是网络空间的主人，人民的利益、网民的诉求是网络安全治理的最大利益。习近平反复强调：“国家安全工作归根结底是保障人民利益，要坚持国家安全一切为了人民、一切依靠人民，为群众安居乐业提供坚强保障。”

习近平网络空间安全治理观



- 4. “核心技术自主创新” 的网络安全技术观
- 习近平指出：“网络安全的本质在对抗，对抗的本质在攻防两端能力较量。” 互联网核心技术是我们最大的“命门”，核心技术受制于人是我们最大的隐患。因此，我们必须牢牢树立核心技术自主创新的网络安全技术观，抓紧突破网络发展的前沿技术和具有国际竞争力的关键技术，构建起以自主创新为主、引进消化吸收为辅的网络技术创新体系。”

习近平网络空间安全治理观



- 5. “尊重网络主权反对霸权” 的网络安全国家观
- 网络主权是国家主权在网络空间的拓展和延伸。放眼网络空间，互联网在带来利好的同时，也使网络安全风险日益突出，网络主权随时面临威胁和挑战。习近平强调：“要理直气壮地维护网络空间主权，明确宣示我们的主张。” 由于网络核心技术一直为发达国家所掌握，根服务器分布也主要集中在少数发达国家手中，所以在较长的时期内，网络空间被西方大国主导，表现出网络霸权。基于维护国家安全，网络安全治理坚持尊重网络主权，反对网络霸权，坚持多样化的发展道路，充分尊重各自选择的网络运行模式和管理政策机制显得尤为重要。



北京邮电大学

Beijing University of Posts and Telecommunications

谢谢大家